



Aufgabenblatt 1: Unternehmenssicherheit bestimmen und Angriffsvektoren

Themenbezug: Schutzziele und CIA, Risikomanagement, rechtliche Rahmenbedingungen, risikobasiertes Sicherheitskonzept, AAA

Bearbeitung: Wenden Sie die folgenden Fragen auf Ihr Unternehmen an. Nutzen Sie konkrete Beispiele aus dem Briefing und keine allgemeinen Lehrbuchdefinitionen ohne Bezug.

1. Schutzbedarf und Risiken

Bestimmen Sie für mindestens drei wichtige Systeme oder Datenbestände Ihres Unternehmens den Schutzbedarf hinsichtlich Vertraulichkeit, Integrität und Verfügbarkeit. Ordnen Sie außerdem mindestens einem System ein erweitertes Schutzziel zu (zum Beispiel Authenticity oder Non Repudiation) und begründen Sie diese Zuordnung. Leiten Sie daraus mindestens drei wesentliche Risiken für das Unternehmen ab.

2. Risikobewertung und Risikomatrix

Stellen Sie eine geeignete Methode zur Risikoberechnung vor (zum Beispiel Risiko gleich Eintrittswahrscheinlichkeit mal Schadensausmaß). Ordnen Sie mindestens drei Ihrer Risiken aus Frage 1 in einer Risikomatrix ein. Wählen Sie anschließend die zwei größten Risiken aus und schlagen Sie jeweils eine passende Strategie der Risikobewältigung vor (Vermeidung, Verminderung, Transfer oder Akzeptanz). Begründen Sie Ihre Wahl jeweils kurz.

3. Rechtliche Vorgaben

Bestimmen Sie mindestens drei rechtliche Vorgaben oder Regulationen, die für Ihr Unternehmen aufgrund seiner Größe, Branche und verarbeiteten Daten relevant sein könnten (zum Beispiel DSGVO, NIS-2, DORA, EU AI Act, CRA, branchenspezifische Regularien). Begründen Sie zu jeder genannten Vorgabe konkret anhand des Briefings, warum sie zutrifft. Prüfen Sie zusätzlich mindestens eine auf den ersten Blick naheliegende Regulation, die bei genauerer Betrachtung tatsächlich nicht zutrifft, und begründen Sie auch das.



4. Risikobasiertes Sicherheitskonzept nach CIS Controls

Ordnen Sie Ihr Unternehmen begründet einer Implementation Group der CIS Critical Security Controls zu (IG1, IG2 oder IG3). Stützen Sie diese Einstufung auf mindestens drei Kriterien aus dem Briefing, etwa Unternehmensgröße und verfügbare IT-/Sicherheitsressourcen, Branche und regulatorisches Risikoprofil (auch im Zusammenhang mit Ihrer Antwort zu Frage 3) sowie Art und Sensibilität der verarbeiteten Daten.

Prüfen Sie anschließend anhand des Abschnitts „Bereits aktive Sicherheitsmaßnahmen“ im Briefing, welche CIS Controls in Ihrem Unternehmen bereits (auch nur teilweise) umgesetzt sind, und benennen Sie zu mindestens zwei bereits vorhandenen Maßnahmen den jeweils passenden CIS Control samt konkretem Safeguard.

Wählen Sie danach mindestens vier der von Ihnen in Frage 1 oder 2 identifizierten Risiken aus und ordnen Sie jedem dieser Risiken einen passenden CIS Control mit einem konkreten, noch fehlenden Safeguard zu, der zur von Ihnen gewählten Implementation Group gehört. Stellen Sie diese Zuordnung für mindestens vier Punkte explizit dar, in der Form “Risiko, CIS Control (Nummer und Name), fehlender Safeguard (Nummer und Name), Priorität” und begründen Sie jeweils kurz, warum genau dieser Safeguard das genannte Risiko wirksam adressiert.

Fassen Sie abschließend zusammen, welche der von Ihnen gefundenen Lücken am dringendsten zu schließen sind, damit Ihr Unternehmen die von Ihnen gewählte Implementation Group insgesamt tatsächlich vollständig erfüllt.

5. Zugriffs- und Berechtigungskonzept (AAA)

Erklären Sie die Begriffe Authentication, Authorization und Accounting anhand mindestens einer konkreten Zugriffssituation aus Ihrem Unternehmen. Beurteilen Sie, ob die im Briefing beschriebene Lösung eher eine zentrale oder dezentrale AAA-Umsetzung ist, und nennen Sie mindestens zwei Indikatoren für Ihre Einschätzung. Schlagen Sie für mindestens zwei unterschiedliche Zugriffsszenarien (zum Beispiel Arbeitsplatz-Login, Fachanwendung, Fernzugriff im Home-Office) jeweils geeignete Authentifizierungsfaktoren vor und begründen Sie Ihre Wahl. Beschreiben Sie anhand eines konkreten Beispiels aus Ihrem Unternehmen, welche Informationen im Rahmen des Accounting protokolliert werden sollten, und wofür diese Protokolle im Streitfall oder bei einem Sicherheitsvorfall genutzt werden könnten.

Präsentieren Sie Ihre Ergebnisse anschließend in einer Präsentation von 10 bis 15 Minuten Dauer.